MITRE ATLAS | AML.CS0039 - Living Off AI: Prompt Injection via Jira Service Management

Entry Information

ID:
AML.CS0039

Type:
Case-Study

Name:
Living Off AI: Prompt Injection via Jira Service Management

URL:
https://atlas.mitre.org/studies/AML.CS0039/

Incident Date:
2025-06-19

Target:
Atlassian MCP, Jira Service Management

Actor:
Cato CTRL

Description

Researchers from Cato Networks demonstrated how adversaries can exploit AI-powered systems embedded in enterprise workflows to execute malicious actions with elevated privileges. This is achieved by crafting malicious inputs from external users such as support tickets that are later processed by internal users or automated systems using AI agents. These AI agents, operating with internal context and trust, may interpret and execute the malicious instructions, leading to unauthorized actions such as data exfiltration, privilege escalation, or system manipulation.

Attack Procedure:
[AML.T0003] Search Victim-Owned Websites: The researchers performed reconnaissance to learn about Atlassian's Model Context Protocol (MCP) server and its integration into the Jira Service Management (JSM) platform. Atlassian offers an MCP server, which embeds AI into enterprise workflows. Their MCP enables a range of AI-driven actions, such as ticket summarization, auto-replies, classification, and smart recommendations across JSM and Confluence. It allows support engineers and internal users to interact with AI directly from their native interfaces.
[AML.T0095] Search Open Websites/Domains: The researchers used a search query, "site:atlassian.net/servicedesk inurl:portal", to reveal organizations using Atlassian service portals as potential targets.
[AML.T0065] LLM Prompt Crafting: The researchers crafted a malicious prompt that requests data from all other support tickets be posted as a reply to the current ticket.
[AML.T0093] Prompt Infiltration via Public-Facing Application: The researchers created a new service ticket containing the malicious prompt on the public Jira Service Management (JSM) portal of the victim identified during reconnaissance.
[AML.T0051.001] Indirect: As part of their standard workflow, a support engineer at the victim organization used Claude Sonnet (which can interact with Jira via the Atlassian MCP server) to help them resolve the malicious ticket, causing the injection to be unknowingly executed.
[AML.T0053] AI Agent Tool Invocation: The malicious prompt requested information accessible to the AI agent via Atlassian MCP tools, causing those tools to be invoked via MCP, granting the researchers

increased privileges on the victim's JSM instance.

[AML.T0085.001] AI Agent Tools: The malicious prompt instructed that all details of other issues be collected. This invoked an Atlassian MCP tool that could access the Jira tickets and collect them.

[AML.T0086] Exfiltration via AI Agent Tool Invocation: The malicious prompt instructed that the collected ticket details be posted in a reply to the ticket. This invoked an Atlassian MCP Tool which performed the requested action, exfiltrating the data where it was accessible to the researchers on the JSM portal.

References

- Cato CTRL™ Threat Research: PoC Attack Targeting Atlassian's Model Context Protocol (MCP) Introduces New "Living Off AI" Risk — https://www.catonetworks.com/blog/cato-ctrl-poc-attack-targeting-atlassians-mcp/